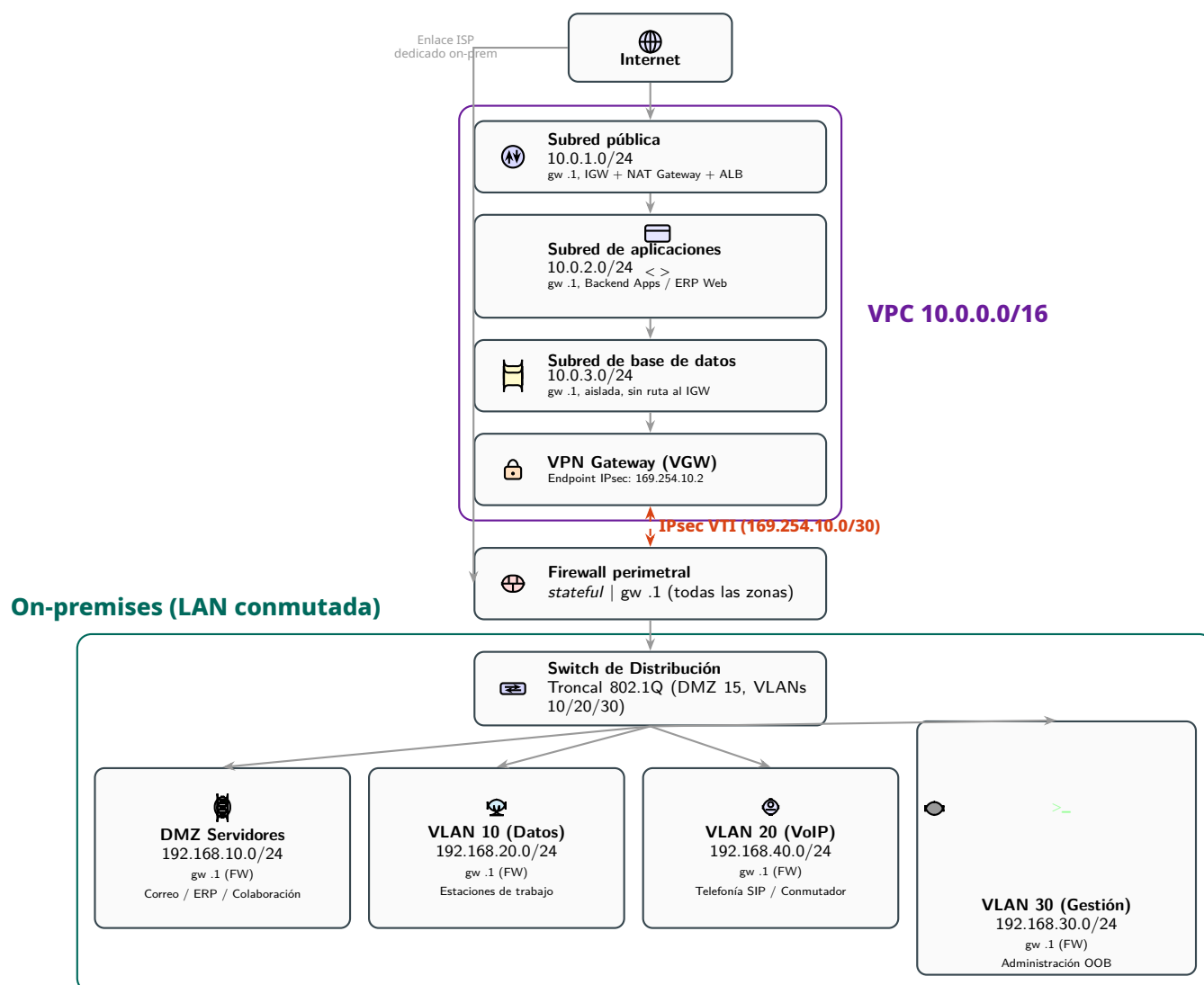


1 Topología de Red



2 Análisis de Riesgos por Capa (L2, L3 y L4)

2.1 Capa 2 — Enlace de Datos

Salto de VLAN

- **Descripción:** El estándar IEEE 802.1Q carece de autenticación nativa en las tramas de control. Un atacante conectado a un puerto de acceso puede forzar un enlace troncal mediante tramas DTP falsificadas o emitir tramas anidadas con doble etiqueta 802.1Q. En este último caso, el primer switch retira la VLAN nativa y retransmite la trama hacia el switch de distribución, el cual procesa la etiqueta interna y entrega el paquete a la VLAN destino sin pasar por las políticas del firewall.
- **Superficie de ataque:** Puertos de red en la subred de estaciones de trabajo ('192.168.20.0/24', VLAN 10) que conserven configuraciones de fábrica (DTP dinámico) o enlaces troncales que mantengan la VLAN nativa predeterminada (VLAN 1).
- **Impacto CIA:** Confidencialidad: **Alta** (permite alcanzar la DMZ de servidores '192.168.10.0/24' o la VLAN 30 de gestión saltándose el firewall); Integridad: **Alta**; Disponibilidad: **Baja**.
- **Probabilidad justificada: Media-Alta.** En edificios corporativos con cableado preexistente, es común que los puertos de acceso compartan bocas de pared con teléfonos IP (puertos con *Voice VLAN* mal configurados) o carezcan de modo acceso estricto.

Envenenamiento de Tablas ARP

- **Descripción:** El protocolo ARP es apátrida y carece de autenticación: cualquier host almacena respuestas gratuitas sin validar la solicitud. Un atacante emite tramas ARP falsificadas asociando la IP del gateway

('192.168.20.1') con su propia dirección MAC, posicionándose como *Man-in-the-Middle* para interceptar o manipular el tráfico saliente.

- **Superficie de ataque:** Dominio de difusión de la VLAN 10 de estaciones de trabajo ('192.168.20.0/24'), caracterizado por la pluralidad de endpoints de usuarios, laptops personales y dispositivos que ingresan al piso arrendado.
- **Impacto CIA:** Confidencialidad: **Crítica** (intercepción de tráfico hacia Internet, correo corporativo y la VPC en tránsito por la VPN); Integridad: **Alta** (inyección de datos o degradación criptográfica); Disponibilidad: **Alta** (agujero negro de tráfico local o *blackholing*).
- **Probabilidad justificada: Alta.** Las estaciones de usuario son el vector de compromiso inicial más vulnerable ante phishing o malware local.

2.2 Capa 3 — Red

Falsificación de Dirección IP de Origen

- **Descripción:** El encabezado IPv4 no valida criptográficamente la autenticidad de la dirección origen. Un atacante forja paquetes asignándoles como origen direcciones de confianza para engañar filtros de firewall no stateful o generar ataques de reflexión y amplificación volumétrica.
- **Superficie de ataque:** Interfaces WAN e internas del firewall perimetral, routers virtuales de la VPC y mecanismos de control de acceso basados exclusivamente en listas de direcciones IP de origen.
- **Impacto CIA:** Confidencialidad: **Baja** (ataque ciego, respuestas viajan a la víctima suplantada); Integridad: **Media-Alta** (inyección de comandos UDP arbitrarios); Disponibilidad: **Alta** (denegación de servicio distribuida por reflexión).
- **Probabilidad justificada: Media.** En el perímetro WAN, el carrier típicamente aplica filtros anti-spoofing; sin embargo, internamente entre interfaces locales o a través del túnel VPN, si el firewall no valida la interfaz física de entrada contra la ruta inversa, el ataque es ejecutable.

Evasión y Envenenamiento de Rutas por ICMP

- **Descripción:** El protocolo ICMP contempla mensajes de tipo 5, diseñados para notificar a un host sobre un gateway más óptimo dentro de la misma subred. Un atacante forja mensajes ICMP Redirect aparejando provenir del gateway legítimo ('192.168.20.1') para alterar la tabla de enrutamiento del kernel de las estaciones, forzando a que envíen sus paquetes a través de un host hostil en Capa 3.
- **Superficie de ataque:** Pila TCP/IP de las estaciones de trabajo en la subred '192.168.20.0/24' que mantengan activo el procesamiento de mensajes ICMP Redirect.
- **Impacto CIA:** Confidencialidad: **Alta** (posicionamiento *on-path* a nivel de Capa 3 para inspeccionar tráfico hacia la VPC); Integridad: **Alta**; Disponibilidad: **Media** (desconexión si el salto redirigido es inalcanzable).
- **Probabilidad justificada: Baja-Media.** Aunque sistemas operativos de servidor modernos desactivan ICMP Redirect por defecto, muchas distribuciones de escritorio y dispositivos IoT/VoIP aún lo aceptan si no han sido endurecidos centralizadamente.

2.3 Capa 4 — Transporte

Inundación TCP SYN

- **Descripción:** Explota la máquina de estados de TCP durante el *three-way handshake*. El atacante emite ráfagas de segmentos TCP SYN sin enviar el ACK final. El firewall y los servidores reservan estructuras de memoria durante el tiempo de espera, agotando la memoria de la tabla de conexiones del firewall perimetral.
- **Superficie de ataque:** Interfaz WAN del firewall on-premise (puertos de VPN UDP 500/4500 o servicios publicados como SMTP 25 y Mattermost 443), así como el balanceador público en la VPC ('10.0.1.0/24').
- **Impacto CIA:** Confidencialidad: **Nula**; Integridad: **Nula**; Disponibilidad: **Crítica** (colapso de la tabla de estados del firewall on-premise, caída del túnel VPN IPsec y denegación de acceso general a Internet y al ERP).
- **Probabilidad justificada: Media-Alta.** Es el vector DoS perimetral más común en Internet. Los equipos perimetrales en oficinas arrendadas poseen memoria finita frente a botnets comerciales.

Secuestro de Sesión TCP mediante Inyección RST

- **Descripción:** Un atacante con capacidad de observar o inferir números de secuencia TCP válidos genera segmentos falsificados con la bandera RST que caen dentro de la ventana de recepción activa [7], forzando la terminación abrupta del socket o inyectando datos arbitrarios en conexiones de texto plano.
- **Superficie de ataque:** Sesiones de base de datos entre el ERP local ('192.168.10.30') y la base de datos en nube ('10.0.3.50') a través de la VPN si no viajan encapsuladas bajo un protocolo con autenticación criptográfica de sesión.

- **Impacto CIA:** Confidencialidad: **Media**; Integridad: **Alta**; Disponibilidad: **Alta** (*teardown* abrupto de transacciones financieras críticas del ERP).
- **Probabilidad justificada: Media.** Requiere previamente una posición *on-path* (conseguida vía ARP Spoofing) o predictibilidad en los números de secuencia iniciales por baja entropía en kernels antiguos.

3 Propuesta de Mitigaciones

Capa	Ataque	Mitigación	Impacto y Efecto Técnico	Responsable
L2	Salto de VLAN	1. <code>switchport mode access</code> forzado en puertos de usuario. 2. Desactivar negociación DTP 3. Asignar VLAN nativa a ID huérfano sin uso ni IP. 4. Podado manual.	Elimina la negociación clandestina de troncales y descarta tramas con doble etiquetado 802.1Q en hardware.	Administrador de Redes
L2	Envenenamiento ARP	1. Habilitar DHCP Snooping ; uplinks hacia el FW como confiables y puertos de usuario no confiables. 2. Dynamic ARP Inspection (DAI) en VLANs de datos y servidores. 3. Tasa límite: 4. Port Security : máx. 1 MAC por puerto con violación.	El switch valida cada paquete ARP contra la base de datos de DHCP Snooping, descartando tramas envenenadas e impidiendo MitM.	Administrador de Redes
L3	Falsificación de IP	1. Filtrado de ingreso según BCP. 2. Habilitación de uRPF estricto en interfaces internas y túnel VTI. 3. Reglas explícitas <i>anti-spoofing</i> en WAN: descartar paquetes con IP origen RFC 1918 (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16) y <i>bogon IPs</i> .	Descarta tráfico si la interfaz de llegada no coincide con la mejor ruta de retorno en la FIB, bloqueando ataques de reflexión y falsificación.	Ingeniero de Seguridad
L3	Evasión por ICMP	1. Kernel hardening en hosts 2. Regla en firewall perimetral: descartar ICMP Tipo 5 (<i>Redirect</i>) inter-VLAN. 3. <i>Rate limiting</i> estricto para ICMP Tipo 3 y Tipo 8.	Invalida la alteración maliciosa de tablas de rutas locales en los endpoints y frena el escape activo de la red.	SysAdmin / SecOps
L4	Inundación SYN	1. TCP SYN Cookies en firewall y balanceadores al superar umbral $\geq 75\%$ de tabla de estados. 2. Modo SYN Proxy en firewall para correo (25) y Mattermost (443). 3. Límites de tasa: máx. 50 conexiones semiabiertas por IP origen. 4. Mitigación anti-DDoS / Cloud Scrubbing con el ISP.	Previene el agotamiento de memoria del firewall stateful sin descartar conexiones legítimas, salvaguardando el túnel IPsec.	Ingeniero de Seguridad Perimetral
L4	Secuestro de Sesión	1. Cifrado en tránsito obligatorio con TLS 1.3 en ERP, correo y colaboración. 2. Conexiones a base de datos en nube (10.0.3.0/24) mediante mTLS nativo autenticado por certificados sobre la VPN. 3. Generación aleatoria robusta de ISN.	Neutraliza la observación o inyección de cargas útiles aun con posición <i>on-path</i> e invalida paquetes RST ciegos fuera de ventana.	Arquitecto de Software / SysAdmin

4 Riesgos Residuales

1. **Ámbito On-Premises (Compromiso de Identidades y Acceso Físico en Edificio Compartido):** Las defensas L2/L3 validan tramas y puertos, pero son transparentes si un endpoint autorizado es comprometido mediante phishing o infostealers. Asimismo, al rentar en un edificio corporativo en Reforma, el cuarto de telecomunicaciones principal y los ductos verticales son compartidos y operados por personal del inmueble y múltiples carriers externos.
 - *Acciones concretas:* Desplegar control de admisión con certificados de máquina para abrir puertos, agentes **EDR** para aislamiento reactivo, autenticación multifactor y gabinete propio cerrado bajo llave con chapa electrónica y CCTV 24/7 en el IDF de piso.
2. **Ámbito Nube (Deriva de Configuración y Abuso de Identidad Cloud - IAM):** Aunque la VPC aísla las subredes de aplicación (10.0.2.0/24) y bases de datos (10.0.3.0/24), la operación diaria propicia reglas temporales permisivas en *Security Groups* que nunca se retiran o asignación excesiva de permisos en roles IAM.
 - *Acciones concretas:* Implementar herramientas de postura de seguridad (**CSPM**) con auditorías continuas según CIS Benchmarks y gestionar la totalidad de la red cloud exclusivamente mediante Infraestructura como Código (**IaC / Terraform**) con análisis estático en CI/CD.
3. **Ámbito de Interconexión (Punto Único de Falla en Última Milla y Movimiento Lateral):** La VPN cifra el canal lógico, pero depender de una sola acometida de fibra en la oficina crea un punto único de falla ante un corte físico en la vía pública o falla en el switch del MMR. Por otra parte, si un host local es comprometido, el túnel transporta tráfico malicioso hacia la nube si no hay inspección de Capa 7.
 - *Acciones concretas:* Contratar un enlace de respaldo diversificado por radiofrecuencia (microondas en azotea) o fibra por calle divergente; tratar la terminación VPN en el firewall como zona no confiable (*Untrusted*) aplicando inspección profunda L7 (NGFW/IPS) y microsegmentación estricta.

4.1 Sustitución de VPN Site-to-Site por un Enlace Dedicado

4.1.1 Cambios en la Superficie de Ataque

- **Superficie Eliminada / Reducida:** Se cierran en la WAN los puertos de negociación IKE (UDP 500 y 4500), erradicando escaneos masivos, ataques de fuerza bruta al PSK, explotación de vulnerabilidades y ataques DDoS volumétricos dirigidos a la IP pública del firewall. Se mitiga el riesgo de secuestro de rutas BGP en el Internet global.
- **Superficie Introducida / Agravada:**
 - *Tráfico en claro por defecto:* Los enlaces dedicados son canales privados L2/L3, pero **no vienen cifrados de forma nativa**. Si no se añade cifrado, personal del carrier o terceros con acceso al MMR del edificio pueden interceptar el tráfico del ERP o bases de datos.
 - *Exposición del plano de control BGP:* La interconexión utiliza sesiones BGP dinámicas, introduciendo vectores de inyección de rutas falsas (*route poisoning*), fugas de prefijos (*route leaks*) y ataques DoS por inyección de paquetes TCP RST contra la sesión BGP.
 - *Riesgo en cadena de suministro de telecomunicaciones:* Mayor dependencia de la integridad física de las conexiones cruzadas y riesgo de configuraciones erróneas del carrier.

4.1.2 B. Mitigaciones Técnicas en Capas de Enlace y Red

- **Capa 2 (Enlace):** Implementar **MACsec** con AES-GCM-256 punto a punto directamente en la interfaz física de conexión cruzada contra el proveedor de nube para proteger contra interceptación pasiva en el MMR. En enlaces *Hosted*, aplicar aislamiento estricto de VLANs 802.1Q descartando tramas sin etiquetar.
- **Capa 3 (Red):** Si MACsec no es soportado, encapsular un túnel **IPsec sobre el Enlace Dedicado** con IKEv2 y AES-256-GCM. Proteger la sesión BGP mediante **TCP-AO** o MD5; aplicar filtrado estricto de prefijos anunciando únicamente prefijos locales y aceptando estrictamente el bloque 10.0.0.0/16 de la VPC y activar **BFD** para convergencia ante fallas en milisegundos.

4.1.3 Análisis Costo / Beneficio en Seguridad

Criterio	VPN Site-to-Site (IPsec sobre Internet)	Enlace Dedicado (Direct Connect / ExpressRoute)
Exposición Perimetral Confidencialidad	Alta: Puertos IKE UDP 500/4500 expuestos a todo Internet. Nativa: Cifrado criptográfico obligatorio (AES-256).	Nula en Internet: Tráfico canalizado fuera de la red pública. Opcional: Requiere configurar explícitamente MACsec o IPsec encima.
Rendimiento y SLA	Mejor esfuerzo: Latencia variable y jitter; vulnerable a congestión.	Garantizado: Ancho de banda reservado, latencia determinada y SLA.
Complejidad y Costo	Bajo: Utiliza el enlace ISP existente; aprovisionamiento ágil.	Muy Alto: Renta mensual de circuito al carrier; puerto cloud y cross-connects.
Punto Único de Falla	Físico: Acometida local de Internet del edificio.	Físico: Circuito del carrier (requiere segundo enlace o VPN de backup).

5 Referencias

Referencias

- [1] K. Scarfone and P. Hoffman, *Guidelines on Firewalls and Firewall Policy*, NIST Special Publication 800-41 Rev. 1, National Institute of Standards and Technology, Sep. 2009. <https://csrc.nist.gov/pubs/sp/800/41/r1/final>
- [2] IEEE, *IEEE Standard for Local and Metropolitan Area Networks—Bridges and Bridged Networks*, IEEE Std 802.1Q-2022, Dec. 2022. <https://standards.ieee.org/ieee/802.1Q/10323/>
- [3] D. C. Plummer, *An Ethernet Address Resolution Protocol*, RFC 826, Nov. 1982. <https://www.rfc-editor.org/rfc/rfc826>
- [4] J. Postel, *Internet Protocol*, RFC 791, Sep. 1981. <https://www.rfc-editor.org/rfc/rfc791>
- [5] P. Ferguson and D. Senie, *Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing*, RFC 2827, BCP 38, May 2000. <https://www.rfc-editor.org/rfc/rfc2827>
- [6] J. Postel, *Internet Control Message Protocol*, RFC 792, Sep. 1981. <https://www.rfc-editor.org/rfc/rfc792>
- [7] W. Eddy, Ed., *Transmission Control Protocol (TCP)*, RFC 9293, STD 7, Aug. 2022. <https://www.rfc-editor.org/rfc/rfc9293>
- [8] IEEE, *IEEE Standard for Local and Metropolitan Area Networks—Port-Based Network Access Control*, IEEE Std 802.1X-2020, Feb. 2020. <https://standards.ieee.org/ieee/802.1X/7299/>
- [9] IEEE, *IEEE Standard for Local and Metropolitan Area Networks—Media Access Control (MAC) Security*, IEEE Std 802.1AE-2018, Dec. 2018. <https://standards.ieee.org/ieee/802.1AE/7154/>
- [10] J. Touch, A. Mankin, and R. Bonica, *The TCP Authentication Option*, RFC 5925, Jun. 2010. <https://www.rfc-editor.org/rfc/rfc5925>